CYBERSECURITY INTERNSHIP — PRACTICAL LAB REPORT

DAY 02: Email Harvesting & Social Engineering Preparation

Intern Name:	Md Peer Siddiqui	**Program:**	Alpha 2 — Cybersecurity Track
Issuing Body:	Sqrock IT Solution	**Date of Execution:**	October 21, 2026
Target Environment:	Local Lab Simulation (Apex Dynamics Inc.)	**Primary Tools:**	Python 3.14, Requests, Regex (re)

1. Curriculum Scope vs. Advanced Tool Capabilities

Sqrock Prescribed Minimum Requirements	Advanced Capabilities Built into Harvester Tool
• Write a Python script using regex • Scrape emails from practice/lab website • Remove duplicate entries using set() • Short write-up on attacker exploitation	• **Dual Source Engine:** Fetches remote HTTP(S) URLs & local offline HTML testbeds • **RFC Email Regex:** Handles subdomains, plus-tags, and cleans punctuation artifacts • **Automated Pretexting Engine:** Evaluates department risk (Finance, HR, IT Support) • **Threat Vector Mapping:** Predicts BEC, malicious CV macros, and credential lures • **Audit Deliverable:** Automatically exports structured JSON report to reports/

2. Harvested Email Intelligence & Threat Vectors

#	Harvested Address	Department	Risk Level	Predicted Attacker Pretext / Threat Vector
1	`billing-invoices@apexdynamics-lab.local`	Finance	CRITICAL	Business Email Compromise (BEC): Fake overdue supplier invoice requiring urgent wire transfer.
2	`careers@apexdynamics-lab.local`	HR / Talent	HIGH	Weaponized Macro Lure: Phishing resume with malicious macro (.docm/.pdf) to gain initial foothold.
3	`finance.desk@apexdynamics-lab.local`	Finance	CRITICAL	CEO Impersonation Fraud: Spoofed executive directing payroll reroute or confidential gift card scam.
4	`hr-department@apexdynamics-lab.local`	HR	HIGH	Employee Verification Lure: Inquiring about employee identity to harvest internal employee directory.
5	`info@apexdynamics-lab.local`	General	MEDIUM	Reconnaissance Pivot: General query to map response timing, auto-responder signatures, and internal mail servers.
6	`it-support@apexdynamics-lab.local`	IT Support	CRITICAL	Credential Phishing: Cloned SSO login page claiming mandatory MFA certificate renewal.
7	`security-ops@apexdynamics-lab.local`	IT Security	CRITICAL	Incident Response Spoofing: Alerting users of 'active breach', requesting temporary elevated permissions.

3. In-Depth Security Analysis: Pretexting Mechanics

What is Pretexting? Pretexting is the psychological foundation of social engineering. Unlike brute-force attacks that attack technical vulnerabilities, pretexting attacks human cognitive biases (authority, urgency, scarcity, and trust). By scraping specific departmental email addresses, an adversary eliminates guesswork and custom-tailors an identity that fits the victim's organizational context.

Why Address Harvesting Enables Multi-Stage Attacks:
1. **Footprinting Organization Structure:** Harvested prefixes (e.g. careers@, billing@) identify existing internal departments, internal naming conventions, and third-party vendors.
2. **Bypassing Email Gateways:** Emails sent to publicly exposed departmental aliases are rarely blocked by spam filters because these addresses are designed to receive external incoming communications.
3. **Targeting High-Value Roles:** Finance employees who process transactions are prioritized for Business Email Compromise (BEC), while HR employees are targeted with weaponized resume attachments.

4. Defensive Countermeasures & Engineering Mitigations

Defensive Layer	Recommended Implementation	Effectiveness Against Harvesters
1. Contact Obfuscation	Replace plaintext mailto: tags with server-side web contact forms protected by reCAPTCHA v3 or Cloudflare Turnstile.	Completely prevents automated regex web scrapers from identifying contact addresses.
2. Email Authentication	Enforce strict **SPF (Sender Policy Framework)**, **DKIM cryptographic signatures**, and **DMARC policy (p=reject)**.	Prevents external attackers from spoofing legitimate corporate domains in spear-phishing campaigns.
3. Email Gateway Sandboxing	Deploy Advanced Threat Protection (ATP) solutions (e.g. Proofpoint, Mimecast) with attachment sandboxing and link rewriting.	Neutralizes weaponized macro attachments sent to HR and analyzes inbound phishing links.
4. Out-of-Band Verification	Establish mandatory phone verification protocols for any wire transfer or payment change request over $1,000.	Eliminates wire transfer fraud even if finance addresses are successfully targeted.

5. Ethical Compliance & Conclusion

This laboratory exercise successfully validated the role of automated Python regex tools in passive social engineering preparation. All data collection was conducted exclusively on local, simulated practice assets (lab_target.html) in full compliance with the **Indian Information Technology Act, 2000** and the **US Computer Fraud and Abuse Act (CFAA)**. At no point were external, unauthorized, or production systems probed.